

II.A.1 Strategic Planning

The board and senior management should evaluate whether the IT strategic plans align with the enterprise-wide business and strategic plan, as well as established priorities. Management should address the following key factors of strategic planning:

- **Participation of senior management:** Senior management should understand and support AIO activities and confirm the inclusion of those activities in the IT strategic plan. Senior management should continuously review the strategic planning process and incorporate changes, as appropriate.
- **Responsibilities within the AIO functions:** Management should define the responsibilities in AIO and determine whether the IT strategic planning process enables personnel to work toward achieving enterprise-wide business and strategic plan objectives.
- **Evaluation of architecture:** Management should evaluate the entity's current architecture and determine whether it meets enterprise-wide business and strategic plan objectives. If necessary, management should adjust its architecture to meet those plan objectives.
- **Impact of IT infrastructure:** Management should understand the relationship between IT infrastructure and the enterprise-wide business and strategic plan objectives. IT infrastructure should directly support IT operations activities to meet IT strategic needs.
- **Post-implementation evaluation:** Management should perform a post-implementation evaluation of the performance and results of IT projects and initiatives to determine whether each project achieved the anticipated benefits and stayed on budget or provided justification for cost variances. The evaluation should be based on management-defined metrics.

When considering whether AIO elements meet strategic plans, and to align with IT and enterprise-wide strategies, management should do the following:

- Evaluate whether past and current IT performance can support the planned IT strategy or future IT activities.
- Take steps to ensure and validate that the IT department is delivering services on time, within budget, and to business specifications.
- Balance resource investments between systems that support current operations and systems that transform operations and enable business units to grow and compete in new areas.

At a larger or more complex entity that provides IT services internally (e.g., help desk or in-house development teams) or externally as a third-party service provider (e.g., core processing providers or cloud service providers), management may consider the following in the IT strategic planning process:

- **IT services strategy management:** Service strategy defines the perspective, position, plans, and patterns that can be used to meet business outcomes. An IT service strategy helps management meet the needs of the entity (e.g., performance increase or constraint removal) while also providing for availability, capacity, continuity, and security.
- **Financial management for IT services:** Financial management for IT services is a method of allocating the cost of providing those services through contractual agreements or service-

level agreements (SLAs). The scope of financial management for IT services could include budgeting to control income and expenses, accounting for expenditures, and customer billing.

- **Service portfolio management (SPM):** SPM enables the entity to balance the investment in AIO with the ability to meet business outcomes. SPM provides for the following:
 - Decisions regarding services offered (e.g., cost benefit analysis).
 - Service catalog, including services that support IT functions.
 - Customer evaluations of services provided.
 - Control of services provided.
 - Planning and periodic assessment for a service's end-of-life (EOL).
- **Demand management:** Demand management includes consideration of customer demand for services and the entity's capacity to meet that demand.

II.A.2 Enterprise Risk Management

Management should implement an ERM structure that incorporates the functions of AIO. ERM should include a consistent and current review of the entity's products, processes, applications, infrastructure, interconnectivity, and other related risks to business operations. Depending on the entity's size and complexity, AIO may be incorporated into ERM in a less formal manner. For more information on ERM, refer to the *IT Handbook's* "[Management](#)" booklet.

Management should establish and maintain an effective risk management process for initiating and overseeing all AIO-related activities, including those that are outsourced. Management should consider doing the following when developing its risk management process for coverage of AIO risks:

- Perform an initial assessment of the entity's AIO-related risk.
- Design architecture to meet the entity's business goals or objectives, including enterprise and IT alignment, integration and interoperability, change management, and IT performance.
- Use infrastructure and appropriate implementation processes to support the entity's strategic objectives.
- Identify infrastructure assets (e.g., hardware and software) and associated interconnectivity critical to business and IT operations.
- Perform ongoing monitoring to identify and evaluate changes in risk from the initial assessment and periodically update the assessment.
- Identify and document roles, responsibilities, procedures, and reporting mechanisms for risk management in AIO activities.
- Define risk tolerances and risk and performance metrics for AIO activities.

II.B Other Roles and Responsibilities

Board oversight of IT, and subsequently the IT environment, is discussed in the *IT Handbook's* "[Management](#)" booklet. There are, however, specific governance topics related to operational oversight discussed in this booklet. Entities may use different titles than those illustrated within this booklet; the responsibilities described, however, should be appropriately assigned. Common

responsibilities and those responsibilities specific to architecture, infrastructure, and operations are described within the relevant sections.

II.B.1 IT Management Responsibilities

IT management is composed of individuals with responsibility for overseeing the management, maintenance, and use of IT resources. While the titles of these individuals may vary, common titles include chief information officer (CIO) or chief technology officer (CTO). For more information about CIO and CTO roles, refer to the *IT Handbook's* "[Management](#)" booklet. The CIO or CTO may also be responsible for overseeing the architecture function, implementing and maintaining the entity's infrastructure, and managing IT operations in an integrated IT environment. A specific individual (e.g., IT manager or chief architect) or a team (e.g., enterprise architecture [EA]) can carry out the architecture function's responsibilities. Generally, management should assign responsibilities based on the complexity of the entity's architecture needs. Responsibilities for architecture and data management may fall to a chief architect or a data officer; however, in smaller or less complex entities, these responsibilities may be rolled into one or more other roles. In such cases, management should maintain appropriate separation of duties. Regardless of how they are assigned, common responsibilities are described in the following sections.

II.B.1(a) *Chief Architect*

A chief architect or enterprise architect is an individual responsible for the IT architecture process that reviews how IT functions can be centralized, allowing departments across the entity to work together seamlessly. This individual should understand interrelationships between IT and the entity's business functions. The chief architect may be a C-level executive and, depending on the entity's complexity, may oversee and coordinate the efforts of other technology-specific architects, (e.g., chief security architect, chief data architect, and chief cloud architect). Architecture responsibilities typically include the following:

- Developing and maintaining the enterprise model and repository and establishing a common understanding, vocabulary, and blueprint for all stakeholders. In smaller or less complex entities, a formal chief architect may not be named, but the responsibilities should be addressed according to the entity's size and complexity.
- Maintaining responsibility for designing the entity's IT architecture to achieve the enterprise-wide business and strategic plan objectives.
- Designing the architecture to accommodate IT changes in a way that maximizes value and minimizes issues associated with changes.
- Communicating to the board and senior management any challenges (e.g., changing industry trends or resource constraints) in meeting those goals.
- Maintaining representations (e.g., blueprints, network diagrams, and topologies) of the entity's IT environment to help ensure that geographically diverse business units and divisions operate in an integrated manner.
- Reviewing existing infrastructure and operations and working with other members of management to determine the capabilities needed by IT systems to deliver new products and services.

- Working with other members of management to evaluate the implication of strategic planning (e.g., significant changes to architecture) on the entity's technology landscape.¹⁰
- Maintaining process and technical knowledge about security, storage, data management, and network service delivery.
- Utilizing appropriate knowledge of IT architecture, structural design (e.g., layout and capacity to meet business needs), business operations, and current technologies.

The chief architect typically reports directly to the CIO or other senior management and often works with the CIO to do the following:

- Develop IT architecture policy and terminology.
- Oversee IT architecture product development, use, and refinement.
- Serve as owner of the IT architecture repository.

II.B.1(b) *Chief Data Officer*

Typical responsibilities of a chief data officer (CDO) include enterprise-wide governance and use of information or data as an asset and assisting in protecting that data and deriving maximum value from it. Other responsibilities may include development of data-related policies, data life cycle management, data asset management (e.g., standardizing data formats and sharing data assets), oversight of compliance with applicable laws and regulations, and conformance with data management industry practices. The CDO provides input to the chief architect in the design of IT systems to promote alignment with enterprise-wide business and strategic plan objectives. This individual may be a C-level or senior executive who also reports to and works with other C-level personnel to manage risk. In smaller or less complex entities, this role may not be separate. Regardless, the responsibilities should be addressed. The CDO also performs the following:

- Oversees data management and data analysis and manages data-related projects (e.g., migrating data to the cloud or implementing a data analytics program).
- Analyzes whether the entity's products and services meet enterprise-wide business and strategic plan objectives from a data perspective.
- Makes data and reporting tools accessible to the entity's stakeholders, maintains data quality, and enables trust in data integrity.
- Owns the entity's strategic use of data and helps the entity perform more efficiently, improve productivity and revenue, and create business opportunities and innovation.
- Communicates information about the entity's data and analytics to appropriate stakeholders.
- Defines a data strategy to enable information sharing and meet compliance objectives and the entity's security requirements.
- Evaluates data and its usage across the enterprise rather than serving a specific business unit. When developing products, considers planning the data and analytics platform first, then defining the release plan and road map.

¹⁰ An entity's technology landscape includes the entity's IT environment in which they directly operate, any direct interactions with the entity's third-party service providers, and other technology considerations outside of the entity (e.g., global security issues, competitor IT initiatives, and new technologies).

- Develops the metrics for monitoring data activities to meet customer needs, not just performance related to projects or programs.

II.B.1(c) *IT Operations Management*

IT operations management is responsible for overseeing the IT environment, including performing and administering the day-to-day technology operations, security, and resilience. It is responsible for managing the capacity, performance (e.g., speed and flow of data), and availability of the components used in an entity's infrastructure, including hardware, networks and telecommunications, software, and storage. Whether centralized or decentralized, IT operations management should support line-of-business and functional operations by facilitating enterprise information systems reporting, product and service development, service delivery, and transaction processing.

II.B.2 IT Operations Personnel Responsibilities

IT operations personnel are responsible for the day-to-day operating and maintenance of the infrastructure components to support the entity's business operations. The following are some examples of their responsibilities and functions:

- Network infrastructure management
 - Network and connectivity for internal and external communication.
 - Remote access.
 - Internal and external telecommunications management.
 - Port management.
 - Network monitoring and issue resolution.
- Server and device management
 - Servers (on premises and off premises).
 - Storage solutions.
 - Entity-supported devices (e.g., desktops, laptops, and mobile devices) and personally owned devices (e.g., mobile devices and personal assistants) where used.
- IT environment management
 - Facility management, including data centers and connectivity to third-party service providers.
 - Help desk management.
 - Identity and access management (IAM).
 - Backup and replication management.
 - Configuration management.
 - IT environment resilience.
 - Cyber and information security.
 - IT project management.

The following are examples of common titles, roles, and responsibilities within IT operations:

- **Database administrator (DBA):** An individual or department responsible for the maintenance of security and information classification of the data stored on a database

system(s). This responsibility includes the design, build, maintenance, and performance tuning of the database. DBAs use specialized software tools to store and organize data to support the entity's business needs.

- **Systems analyst:** An IT professional who coordinates with stakeholders to promote the effective and efficient functioning of infrastructure. Systems analysts research problems, develop solutions, and recommend appropriate courses of action. Systems analysts serve as translators between business and IT personnel by communicating each stakeholder's requirements and constraints. Systems analysts use their knowledge of the entity's computer systems, procedures, and technology needs to help IT personnel design systems that support the enterprise-wide business and strategic plan objectives. They may manage projects or assist with activities related to third-party service providers.
- **Client support specialist:** An individual who assists employees, clients or customers, and third parties. Client support specialists use computer software and equipment to facilitate business needs and troubleshoot software and hardware issues. Client support specialists may also be referred to as user support specialists or "help desk" depending on the type of users they assist. In entities with a service management function, the role of the client support specialist may be carried out by service request or problem management personnel.
- **Systems administrator:** An individual or group responsible for overseeing the day-to-day operability of a computer system or network. Systems administrators install and maintain information systems, support effective system utilization, and implement policies, procedures, and security controls.
- **Network administrator:** Manages a network within an organization. Responsibilities include network security, software installation, distribution of software upgrades, daily activity monitoring, enforcement of licensing agreements, development of a storage management program, and performance of routine backups. Network administrators may design and analyze network infrastructures and make decisions regarding hardware and software upgrades.

II.C Policies, Standards, and Procedures

Management should document and maintain policies, standards, and procedures related to AIO. Smaller or less complex entities may have one policy and related procedures that encompass AIO, while larger or more complex entities may have multiple policies, standards, and procedures covering various aspects of AIO or various divisions or departments. Regardless of the entity's size and complexity, management should implement policies, standards, and procedures that address scope, responsibilities, accountability, authority, and guidance to develop and maintain effective processes related to AIO. With respect to AIO, documentation should include the following:

- Policies¹¹ that provide the guiding principles by which an organization designs, builds, and operates its information and technology assets and set the foundation for meeting the entity's objectives. For example, an entity may have policies outlining the types of hardware or software it will or will not use (e.g., "We will not use any unapproved software.").

¹¹ The [National Institute of Standards and Technology's \(NIST\) Glossary](#) defines policies as statements, rules, or assertions that specify the correct or expected behavior of an entity.

- Standards¹² that build on the policies and provide more granular information for AIO activities. For example, standards may explain the types of data that are allowed to reside in the cloud or the types of controls to be implemented to mitigate the risks of data residing in the cloud.
- Procedures¹³ that describe the specific ways for personnel to perform AIO activities. For example, AIO-related procedures may cover topics including how to harden new systems or perform architecture reviews with the necessary steps for personnel to follow.

II.D Internal Audit, Independent Reviews, and Certification Processes

Action Summary

The board and senior management should engage internal audit or other independent personnel or third parties to review AIO functions and activities and validate effectiveness of controls. Effective AIO auditing assists the board and senior management with oversight, helps verify compliance with applicable laws and regulations, and helps ensure adherence to contractual agreements and entity policies, standards, and procedures to mitigate risks.

Examiners should review for the following:

- Independence of AIO-related audits or other reviews.
- Appropriate scope and detail of AIO-related audits or other reviews.
- Applicable reporting of the AIO-related audit results to the board.
- Evaluation of third-party service providers' AIO-related audit or review reports.
- Qualifications of auditors reviewing AIO functions and activities.

The board and senior management should engage audit or use other independent reviews to assess the AIO design, implementation, and operational effectiveness, including the adequacy of policies and procedures and the effectiveness of controls. In many cases, the review of AIO functions and activities will be included within other audits. Audit should review the entity's AIO functions and activities and management's ability to oversee and control risks related to those functions and activities. Auditors should be qualified and knowledgeable to review AIO functions and activities. For example, if an entity uses cloud environments, the auditor should have training and experience reviewing cloud infrastructures. Auditors should be independent of the AIO functions and activities being reviewed. Audit scope and frequency depend on the complexity of the AIO functions and activities; the entity's risk profile; and design,

¹² The [NIST Glossary](#) defines standards as rules, conditions, or requirements that describe the following information for products, systems, services, or practices: (1) classification of components, (2) specification of materials, performance, or operations, or (3) delineation of procedures.

¹³ The [ISACA Glossary](#) defines a procedure as a document containing a detailed description of the steps necessary to perform specific operations in conformance with applicable standards. Procedures are defined as part of processes.

implementation, and operational changes that the entity may experience. Larger or more complex entities may have multiple audits covering various departments or aspects of AIO functions and activities. Smaller or less complex entities may include a review of AIO within an IT general controls audit.

Audit or independent review reports to the board and senior management should provide an independent assessment of management's ability to oversee the entity's AIO functions and activities. For example, as part of their assessment, auditors or reviewers should perform the following:

- Evaluate supporting documents demonstrating that management has based AIO decisions on the entity's business strategy, security, and resilience needs.
- Leverage system and organization controls (SOC)¹⁴ reports and other external audit reports for the entity's third-party service providers to evaluate potential risks to the entity, such as interconnectivity and supply chain risks.
- Identify and report AIO issues to senior management and the board.

Some entities may choose to achieve an external certification (e.g., International Organization for Standardization [ISO] or Payment Card Industry Data Security Standard [PCI DSS]) to demonstrate the effectiveness of controls. These certifications can be reviewed along with audit reports or other independent reviews. Certifications are often a point-in-time assessment, however, and do not replace audit reports.

II.E Communication

Effective communication helps ensure that key issues are understood across the entity, objectives are received and acknowledged by management and staff, and everyone understands his or her role. Effective communication of AIO concepts is critical to bridge discussions and decision-making between technical staff and management. The significance of IT, in terms of investment and potential impact on the entity's business operations, highlights the importance of communicating the risks associated with IT and progress of IT strategic initiatives. Management is responsible for communicating relevant AIO information (e.g., disruptions, initiatives progress, or issue status) to the entity's staff, applicable customers, and third parties.

II.F Board and Senior Management Reporting

Management should report to the board periodically on the status of AIO-related initiatives, progress, issues, and metrics. The board should regularly monitor strategy, security, and resilience activities to verify that they are implemented as envisioned and reviewed (periodically

¹⁴ "In 2017, the [American Institute of Certified Public Accountants (AICPA)]...introduced the term system and organization controls (SOC) to refer to the suite of services practitioners may provide relating to system-level controls of a service organization and system or entity-level controls of other organizations. Formerly, SOC referred to service organization controls. By redefining that acronym, the AICPA enables the introduction of new internal control examinations that may be performed (a) for other types of organizations, in addition to service organizations, and (b) on either system-level or entity-level controls of such organizations." (AICPA, [SOC 2 Examinations and SOC for Cybersecurity Examinations: Understanding the Key Distinctions.](#))

and as changes occur). Board minutes should reflect significant AIO-related discussions, including credible challenges and approvals.

A fundamental element for reporting includes setting baseline metrics against which management can measure performance and risks. Developing, implementing, and monitoring metrics for AIO functions and activities are key for evaluating progress toward achieving strategic goals and business objectives. Common metrics reported to senior management and the board help to identify the following:

- Performance of IT and AIO activities.
- Return on investment for IT.
- Anomalies.
- Areas for improvement (e.g., cost, system, process, or service) providing opportunities for AIO.

III COMMON AIO RISK MANAGEMENT TOPICS

IT systems are designed, built, and implemented to achieve strategic goals and business objectives. While there are risks specific to each of the AIO functions, certain risks are common to all three. Common AIO risk management topics are discussed in the following sections:

- Data governance and data management.
- ITAM.
- Business and IT environment representation.
- Managing change in AIO and change management.
- Oversight of third-party service providers.
- Resilience.
- Remote access.
- Personally owned devices.
- File exchange.

III.A Data Governance and Data Management

Action Summary

Management should promote a culture that takes a data-centric approach for AIO functions and define responsibility and controls as part of data governance and data management processes.

Examiners should review for the following:

- Data identification and classification processes.
- Data management controls for safeguarding data in physical and digital form.
- Effectiveness of processes for monitoring new and existing databases, noncompliant or misconfigured databases, and changes to the databases.
- Effectiveness of processes for securing databases, analytics tools, and reports.
- Processes for controlling non-masked data in non-production environments.
- Processes for patching databases and monitoring whether the patch level of the production database is up to date.

The AIO functions are critical to planning for and implementing IT activities to meet business needs for one of the entity's most critical and valuable assets—data. Management should, therefore, govern and manage data based on the entity-assigned data classification described in the [“Data Identification and Classification”](#) section of this booklet.

Data governance and data management are fundamental to maintaining the confidentiality, integrity, and availability of information. Data governance is a set of processes for formally managing data assets throughout the entity. It establishes authority, management, and decision-